

PURPLE TEAMING

Adversary Emulation Frameworks,
Atomic Red Team & MITRE ATT&CK.

Disusun Oleh: **Rizki Angga Pratama**
L2 SOC Analyst

HAK CIPTA & DISCLAIMER

Purple Teaming & Adversary Emulation Frameworks
Edisi Enterprise (50 Halaman)

Disusun oleh: Rizki Angga Pratama, S. Kom, C. Pro

Buku ini dirancang khusus bagi Detection Engineers, Analis SOC (Tim Biru), dan Penetration Testers (Tim Merah) yang ingin berhenti bekerja secara terisolasi (Siloed) dan mulai mengadopsi operasi kolaboratif berbasis pengujian hipotesis untuk memvalidasi postur deteksi SIEM.

> **Peringatan Lingkungan Operasional (RoE):**
> Seluruh aktivitas Adversary Emulation (seperti injeksi memori, eksfiltrasi, dan credential dumping) yang menggunakan Atomic Red Team atau MITRE Caldera*di dalam buku ini akan memicu respons *Endpoint Detection and Response (EDR)*. Jalankan *framework* ini hanya pada mesin Uji Coba (VM/Staging) dengan persetujuan tertulis (Rules of Engagement), karena agen Caldera berperilaku sangat mirip dengan agen *malware* sesungguhnya (C2).

Filosofi Desain:
Buku ini disajikan dalam balutan warna *Neon Amethyst* (Ungu Tua). Ungu adalah warna yang tercipta saat agresivitas operasi Merah (Offense) bersilangan langsung dengan presisi operasi Biru (Defense).

© 2026 Hak cipta dilindungi undang-undang. Panduan Validasi Deteksi Operasional.

KATA PENGANTAR

Industri keamanan siber secara historis sangat terfragmentasi. Tim Penetration Testing (Tim Merah) menyerang jaringan, mencetak laporan PDF setebal 50 halaman berisi temuan kerentanan, melemparnya ke meja Security Operations (Tim Biru), lalu pergi. Di sisi lain, Tim Biru membaca laporan tersebut dengan frustrasi, menulis ratusan aturan SIEM, tanpa pernah tahu apakah aturan tersebut benar-benar berfungsi jika diserang esok hari.

Siklus destruktif ini berakhir dengan Purple Teaming.

Purple Team bukanlah sebuah departemen baru; ini adalah sebuah metodologi. Alih-alih pengujian tahunan yang buta (*Blind Penetration Test*), operasi Purple duduk di ruangan yang sama (baik fisik maupun virtual). Tim Merah mengeksekusi satu taktik musuh (misalnya Pass-the-Hash), sementara Tim Biru melihat layar SIEM secara *Real-Time*. *"Apakah lanskap log kita menangkapnya? Tidak? Mari kita perbaiki konfigurasinya sekarang juga, lalu coba serang lagi."*

Untuk melaksanakan operasi ini di level *Enterprise* tanpa harus mempekerjakan hacker elit setiap minggu, kita membutuhkan Adversary Emulation Frameworks. Dalam E-Book ini, saya akan mengajarkan cara Anda (sebagai Tim Biru) memutar peladen Command & Control (C2) Anda sendiri menggunakan MITRE Caldera dan mengeksekusi pengujian mikroskopis menggunakan Atomic Red Team untuk memvalidasi arsitektur pertahanan Anda secara matematis.

Keamanan bukan tentang asumsi. Keamanan adalah pembuktian.

— Rizki Angga Pratama

Author

DAFTAR ISI (1/2)

BAGIAN I: Paradigma Tim Ungu (Purple Team)

Bab 1.1 Kesenjangan Historis: Red vs Blue Hlm. 7

Bab 1.2 Transisi dari Pen-Test ke Adversary Emulation Hlm. 8

Bab 1.3 Peran CTI (Cyber Threat Intel) sebagai Kompas Hlm. 9

Bab 1.4 Pemetaan Operasi ke MITRE ATT&CK Matrix Hlm. 10

Bab 1.5 Siklus Hidup Latihan Purple Team (Plan, Execute, Refine) Hlm. 11

BAGIAN II: Atomic Red Team (Emulasi Entry-Level)

Bab 2.1 Pengenalan Atomic Red Team (Red Canary) Hlm. 13

Bab 2.2 Instalasi & Persiapan Lingkungan Uji Hlm. 14

Bab 2.3 Mengeksekusi Tes (Invoke-AtomicTest PowerShell) Hlm. 15

Bab 2.4 Membedah Simulasi T1059.001 (PowerShell Execution) Hlm. 16

Bab 2.5 Simulasi Ekstraksi Kredensial (OS Credential Dumping) Hlm. 17

Bab 2.6 Melacak Telemetri Atomic di Elastic/Splunk SIEM Hlm. 18

Bab 2.7 Fine-Tuning Aturan Deteksi (Mengurangi False Positive) Hlm. 19

DAFTAR ISI (2/2)

BAGIAN III: MITRE Caldera (Advanced Emulation)

Bab 3.1 Apa itu MITRE Caldera? (Autonomous C2) Hlm. 21

Bab 3.2 Anatomi Inti (Agents, Abilities, Adversaries) Hlm. 22

Bab 3.3 Menyebarkan Agen Sandcat (54ndc47) ke Endpoint Target Hlm. 23

Bab 3.4 Membangun Profil Musuh Kustom (YAML Configuration) Hlm. 24

Bab 3.5 Menjalankan Operasi (Operations & Fact Sources) Hlm. 25

Bab 3.6 Caldera vs EDR: Mengaudit Respons Pemblokiran Hlm. 26

BAGIAN IV: Validasi & Rekayasa Deteksi (Detection Eng)

Bab 4.1 Lifecycle Rekayasa Deteksi SIEM Terstruktur Hlm. 28

Bab 4.2 Matriks Klasifikasi (True Positive vs False Negative) Hlm. 29

Bab 4.3 Mengkalibrasi Logika Supresi (Suppression Rules) Hlm. 30

Bab 4.4 Evaluasi Celah Sumber Log (Data Quality Assessment) Hlm. 31

BAGIAN V: Operasionalisasi & Metrik (CI/CD SecOps)

Bab 5.1 Perencanaan Eksekusi (Rules of Engagement) Hlm. 33

Bab 5.2 Komunikasi Operasional & Fase Hotwash Hlm. 34

Bab 5.3 KPI & Metrik (Time-to-Detect, Time-to-Respond) Hlm. 35

Bab 5.4 Automasi Continuous Validation (SecOps CI/CD Pipeline) Hlm. 36

Glosarium Emulasi (A-M) Hlm. 48

Glosarium Emulasi (N-Z) Hlm. 49

Back Cover (The Assumed Breach) Hlm. 50



BAGIAN I

Paradigma Tim Ungu
(Menutup Celah Asumsi Defensif)

BAB 1: PARADIGMA OPERASIONAL

1.1 Kesenjangan Historis: Red vs Blue

Secara tradisional, perusahaan melakukan pengujian keamanan (*Penetration Testing / Red Teaming*) dengan satu tujuan metrik: **Apakah target dapat diretas?**

Tim Merah (Penyerang) sering beroperasi secara rahasia (*Blind*), berusaha menyelinap melewati sensor EDR tanpa ketahuan. Ketika mereka berhasil mengambil alih *Domain Controller*, mereka merayakannya, menulis laporan eksekutif, lalu pergi. Namun, dari sudut pandang Tim Biru (Tim Pertahanan/SOC), nilai pengujian ini sangat rendah.

Tim Biru ditinggalkan dengan kebingungan: *"Log mana yang terlewat? Di menit ke berapa mereka menembus Firewall? Apakah kueri SIEM kita salah? Mengapa Alert tidak menyala?"*

Purple Teaming merombak total pendekatan ini. Dalam *Purple Team*, tujuan utamanya bukan untuk "Menang/Meretas". Tujuan utamanya adalah **Memvalidasi Telemetri dan Deteksi (Detection Coverage)** secara kolaboratif.

1.2 Transisi dari Pen-Test ke Adversary Emulation

Penetration Testing sering berfokus pada eksploitasi kerentanan (seperti CVE *SQL Injection* pada *server web* kuno) untuk mendapatkan akses (*Initial Access*). Sebaliknya, **Adversary Emulation (Emulasi Musuh)** berasumsi bahwa peretas sudah berada di dalam jaringan Anda (**Assume Breach Mentality**).

Emulasi Musuh tidak peduli *bagaimana* peretas masuk. Ia peduli dengan *perilaku taktis* apa yang akan peretas lakukan *setelah* mereka berada di dalam *Endpoint* karyawan (Misal: *Discovery*, *Lateral Movement*, *Command and Control*, *Exfiltration*).

> **Anatomi Latihan Ungu (Transparansi Penuh):**
> Tim Merah: "Saya akan mengeksekusi T1059 (PowerShell) di PC-Budi pada pukul 14:05."
> Tim Biru: "Diterima. Saya sedang memantau layar Kibana (Elastic) untuk Event ID 4688 di PC-Budi. Silakan eksekusi."
> Tim Merah: "Payload dieksekusi."
> Tim Biru: "Saya melihat lognya masuk 2 detik kemudian, namun *Rule Alert* kita tidak menyala karena *Regex* kita gagal menangkap karakter *Base64*. Mari kita perbaiki *Regex*-nya sekarang."

1.3 Peran CTI sebagai Kompas (Threat Intel)

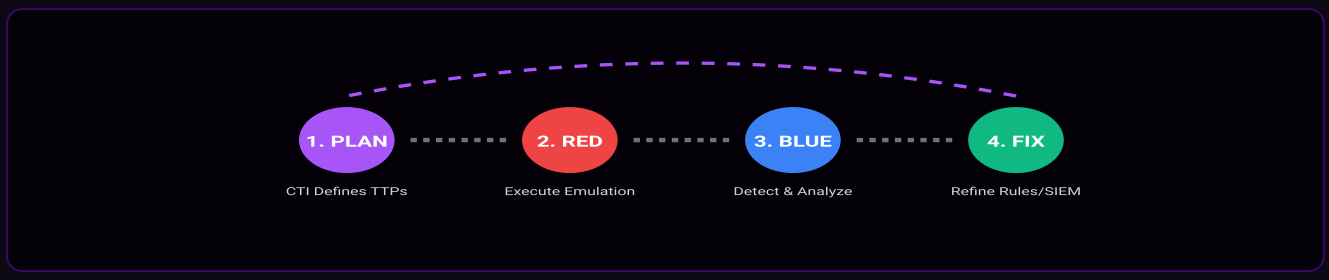
Anda tidak bisa sekadar menyerang secara acak. Anda harus mengemulasi (meniru) musuh yang benar-benar mengancam industri Anda. Di sinilah **Cyber Threat Intelligence (CTI)** bertindak sebagai perencana (Sutradara/Koreografer).

Jika perusahaan Anda adalah Bank di Asia, tim CTI akan memberikan laporan tentang **APT Lazarus (Grup Peretas Finansial)**. CTI memberikan daftar TTPs (*Tactics, Techniques, and Procedures*) yang persis digunakan Lazarus (Misal: Menggunakan SMB *Admin Shares*, menjatuhkan berkas berekstensi `.dat` palsu, mematikan log *Windows Defender*).

Latihan *Purple Team* bulan ini akan didedikasikan secara eksklusif hanya untuk: **"Mengemulasi Kampanye Lazarus, untuk memastikan SOC kita kebal terhadap taktik mereka."** Pendekatan ini membuat latihan keamanan memiliki anggaran (ROI) dan arah yang sangat jelas bagi *Board of Directors*.

1.4 Siklus Hidup Purple Team

Operasi *Purple* bukanlah proyek sekali-jalan, melainkan pipa perbaikan berkelanjutan (*Continuous Improvement Loop*).



Jika pada tahap evaluasi ternyata Tim Biru sama sekali tidak melihat log (*Blind Spot*), masalahnya bukan pada Aturan SIEM (*Rule*), melainkan pada kebijakan audit OS (*Audit Policy*). Tim segera memperbaiki GPO (*Group Policy Object*) di Windows untuk menyalakan modul *Logging*, lalu tes Merah diulang kembali (*Re-test*) di hari yang sama hingga mendeteksi *True Positive*.

1.5 Pemetaan ke MITRE ATT&CK Matrix

Semua latihan Purple Team mutlak membutuhkan bahasa universal. Jika Tim Merah mengatakan "Saya menggunakan Mimikatz", dan Tim Biru mengatakan "Saya memonitor akses LSASS", keduanya membicarakan hal yang sama namun dengan dialek berbeda. MITRE ATT&CK menyelesaikan masalah ini.

Setiap tindakan ofensif dipetakan ke dalam ID Teknik (T-Code). Contohnya, pencurian kredensial LSASS adalah **T1003.001**. Eksekusi *PowerShell* adalah **T1059.001**.

Dengan menggunakan matriks ini, perusahaan dapat mengukur cakupan pertahanan mereka (*Detection Coverage*) secara visual menggunakan warna. Merah berarti belum ada deteksi, Kuning berarti deteksi parsial, dan Hijau berarti deteksi sudah divalidasi dengan simulasi. Latihan Purple Team pada dasarnya adalah proses sistematis untuk mengubah sel-sel matriks MITRE perusahaan Anda dari Merah menjadi Hijau, memberikan bukti empiris kepada manajemen atas kesiapan SOC.



BAGIAN II

Atomic Red Team
(Micro-Emulation Level Entry)

BAB 2: ATOMIC RED TEAM

2.1 Pengenalan (Red Canary)

Bagaimana Anda meniru perilaku peretas tanpa harus menulis skrip *malware* sendiri? **Atomic Red Team (ART)** adalah perpustakaan (*Library*) *open-source* raksasa buatan vendor keamanan *Red Canary*. ART memetakan pengujian mikro (*Atomic Tests*) secara langsung dan presisi ke setiap ID pada MITRE ATT&CK Framework.

Tes "Atomik" berarti tes tersebut kecil, tidak merusak sistem (*Non-Destructive*), dan dieksekusi secara instan dari *Command Line* (seperti Bash atau PowerShell).

Sebagai contoh, jika Tim Biru Anda baru saja menulis aturan deteksi SIEM untuk teknik *Windows Registry Run Keys* (MITRE T1547.001) guna menangkap *malware* yang mencoba *Auto-Start* saat PC menyala. Alih-alih menunggu *malware* asli masuk, Anda bisa membuka ART dan mencari modul T1547.001. Dengan satu baris perintah, ART akan mengeksekusi kunci *registry* persis seperti *malware* sungguhan.

2.2 Instalasi & Persiapan Lingkungan Uji

Meskipun Anda dapat menjalankan perintah *Atomic* secara manual (*Copy-Paste*), metode standar untuk analis *Windows* adalah menggunakan modul *PowerShell* bernama `Invoke-AtomicRedTeam`.

```
# Instalasi Execution Framework di Mesin Uji (VM) IEX (IWR
https://raw.githubusercontent.com/redcanaryco/invoke-atomicredteam/master/install-atomicredteam.ps1 -
UseBasicParsing); Install-AtomicRedTeam -getAtomics # Menampilkan rincian skenario serangan untuk Teknik
Tertentu Invoke-AtomicTest T1003.001 -ShowDetails
```

Sangat disarankan untuk tidak menginstal modul ini di PC produksi atau laptop analis utama Anda. Instal *Atomic Red Team* di dalam *Virtual Machine* (Staging) yang telah dipasangkan agen EDR (CrowdStrike/SentinelOne) dan *Elastic Agent* yang sama persis konfigurasinya dengan PC produksi perusahaan Anda.

2.3 Mengeksekusi Tes (Invoke-AtomicTest)

Setelah modul terinstal, eksekusi serangan hanya berjarak satu baris perintah. Tim Merah akan memberitahukan waktu eksekusi agar Tim Biru dapat memverifikasi stempel waktu (*Timestamp*) di SIEM.

```
# MENGEKSEKUSI SERANGAN (Simulasi OS Credential Dumping via LSASS) Invoke-AtomicTest T1003.001 -
TestNumbers 1 # MEMBERSIHKAN JEJAK SERANGAN (Cleanup agar lingkungan kembali normal) Invoke-AtomicTest
T1003.001 -TestNumbers 1 -Cleanup
```

Fitur `-Cleanup` sangat vital. Setelah tes *Registry* atau tes pembuatan Akun Pengguna Palsu selesai dijalankan (dan alarm SIEM divalidasi), parameter *Cleanup* secara otomatis akan menghapus modifikasi tersebut, sehingga *endpoint* pengujian selalu dalam keadaan steril untuk iterasi berikutnya.

2.4 Membedah Simulasi T1059.001 (PowerShell)

Saat Anda memanggil tes `T1059.001 (PowerShell Execution)`, *Atomic Red Team* tidak sekadar mencetak kata *Hello World*. Ia memanggil modul *YAML* yang berisi teknik musuh nyata yang sering diabaikan oleh deteksi berbasis-*signature* Antivirus tradisional.

Contohnya, *Atomic Test* mungkin akan mengeksekusi injeksi ke dalam memori *PowerShell*, atau mencoba mengunduh fail dari *GitHub* dan mengeksekusinya tanpa menyimpan fail tersebut ke *hard drive* (*Fileless Malware Execution / Download Cradle*).

Bagi Tim Pertahanan (Blue Team), saat tombol *Enter* ditekan oleh Tim Merah, mata mereka tertuju ke SIEM (Elastic/Splunk):

1. Apakah log **Sysmon Event ID 1 (Process Creation)** masuk?
2. Apakah kolom `CommandLine` merekam parameter *Base64* dari eksekusi *PowerShell* tadi, atau log terpotong (*Truncated*) karena batas karakter sistem?
3. Apakah **Script Block Logging (Event ID 4104)** menyala?

2.5 Simulasi Ekstraksi Kredensial (Credential Dumping)

Salah satu taktik paling mematikan yang dilakukan musuh saat berhasil masuk adalah *Credential Dumping* (T1003). Mereka mencoba mencuri kata sandi (*hash*) admin yang tersimpan di dalam memori proses `lsass.exe` Windows.

Atomic Red Team memfasilitasi emulasi ini dengan mengeksekusi procdump dari Sysinternals, atau menggunakan skrip PowerShell yang memanggil API `MiniDumpWriteDump`. Tim Biru harus memantau log akses proses (**Sysmon Event ID 10 - ProcessAccess**).

Jika simulasi ini dijalankan dan SIEM Anda tidak menerima *Event ID 10* dengan target `lsass.exe`, ini berarti sensor EDR Anda buta terhadap serangan ekstraksi kredensial. Menulis *Rule SIEM* secanggih apa pun tidak akan berguna jika log akses memori tersebut tidak pernah dikirimkan dari *Endpoint* ke peladen SIEM.

2.6 Melacak Telemetri di Elastic SIEM

Saat Tim Merah menembakkan emulasi, analis SOC merancang dasbor khusus di **Elastic Security (Kibana)** untuk memantau waktu masuknya log secara langsung (*Real-Time*). Kecepatan (*Latency*) adalah kunci.

Jika tes *Atomic* dijalankan pada 14:00, dan log baru muncul di SIEM pada 14:15, *Pipeline Logstash/Kafka* Anda memiliki *bottleneck* yang berbahaya. Dalam 15 menit, *Ransomware* sudah selesai mengenkripsi separuh pusat data Anda.

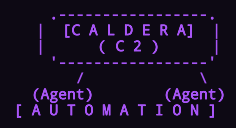
Selain latensi, analis memverifikasi **Kualitas Data (Data Quality)**. Apakah kolom `user.name`, `process.parent.name`, dan `file.path` terisi dengan format ECS (*Elastic Common Schema*) yang benar? Jika log dikirim dalam format mentah (*unparsed XML*) yang tidak bisa diindeks, aturan korelasi Anda tidak akan menyala meskipun serangannya tercatat.

2.7 Fine-Tuning Aturan Deteksi

Hasil akhir dari setiap eksekusi *Atomic* adalah kalibrasi (*Fine-Tuning*). Jika deteksi berhasil menyala, analis SOC memeriksa apakah aturan tersebut terlalu sensitif.

Misalnya, emulasi T1059.003 (Windows Command Shell) memicu aturan *Suspicious CMD Execution*. Namun, ketika diterapkan ke jaringan produksi, aturan ini memicu 500 peringatan palsu (*False Positives*) setiap jam karena perangkat lunak manajemen aset TI (seperti SCCM/Tanium) terus-menerus mengeksekusi skrip `cmd.exe`.

Di sinilah Tim Biru menerapkan logika supresi: `AND NOT (process.parent.executable : "*\\Tanium Client\\tanium.exe")`. Simulasi diulang kembali. Jika peringatan palsu hilang, tetapi deteksi serangan *Atomic* tetap menyala (*True Positive*), maka aturan tersebut dinyatakan matang (*Production Ready*) dan didokumentasikan.



BAGIAN III

MITRE Caldera
(Advanced Autonomous Emulation)

BAB 3: MITRE CALDERA C2

3.1 Apa itu MITRE Caldera?

Atomic Red Team bagus untuk menguji satu teknik tunggal secara manual (Tes unit). Namun, peretas dunia nyata tidak melakukan satu teknik lalu berhenti; mereka melakukan kampanye berantai (*Kill Chain*). Mereka masuk, mencuri kredensial, menyebar secara lateral ke PC lain, lalu mengekstrak data.

Untuk mengemulasikan operasi penuh ini, *MITRE Corporation* membangun perangkat lunak otonom bernama **Caldera**. Caldera pada dasarnya adalah peladen **Command & Control (C2)** fungsional layaknya *Cobalt Strike*.

Sebagai *Purple Team*, Anda menginstal peladen Caldera secara lokal di jaringan Anda. Berbeda dengan C2 peretas yang dikendalikan manual oleh operator, Caldera digerakkan oleh mesin keputusan (AI Emulation). Anda cukup memerintahkannya: *"Jadilah Grup APT29, dan serang jaringan ini!"*. Caldera akan secara otomatis menjalankan ratusan langkah peretasan secara logis.

3.2 Anatomi Inti Caldera

Arsitektur Caldera berpusat pada komponen konseptual yang harus dipahami oleh teknisi *Purple Team* sebelum merancang operasi:

- **Agents (Sandcat/54ndc47):** Ini adalah *Malware* jinak (*Payload*) berbentuk *Golang executable* yang Anda tanam di PC Target. Agen ini melakukan *Beaconing* (menghubungi kembali) peladen Caldera melalui HTTP/HTTPS untuk meminta instruksi secara berkala.
- **Abilities (Kemampuan):** Kumpulan skrip taktik mikro (mirip dengan tes *Atomic*) yang dipetakan ke *MITRE ATT&CK*. Sebuah *Ability* berisi perintah spesifik (seperti mencari berkas kata sandi, atau mematikan *Windows Defender*).
- **Adversaries (Musuh):** Ini adalah *Profile* Kampanye. Anda menyusun *Adversaries* dengan menggabungkan beberapa *Abilities* menjadi satu urutan logis. (Misal: Masuk -> Enkripsi File -> Hapus Backup).

3.3 Menyebarkan Agen Sandcat

Untuk memulai operasi Caldera, Tim Merah harus menanamkan agen pendengar di mesin pengujian. Caldera menyediakan *plugin* **Sandcat (54ndc47)**, sebuah agen lintas platform (Windows/Linux/Mac) yang sangat ringan.

Anda mengunduh agen ini melalui terminal target menggunakan instruksi *cradle* (seperti PowerShell `Invoke-WebRequest`) yang diarahkan ke peladen Caldera lokal Anda. Setelah dieksekusi, Sandcat akan segera mendaftarkan dirinya ke dalam dasbor *Caldera UI*, mengirimkan informasi OS, arsitektur, dan tingkat hak istimewa (*Privilege Level*: User atau SYSTEM).

Sebagai langkah pengujian awal bagi Tim Biru, proses pendaftaran (*Beaconing*) Sandcat ini sendiri **seharusnya memicu alert C2** di jaringan. Jika EDR atau *Firewall* Anda membiarkan *executable* tidak dikenal melakukan *polling HTTP* secara periodik ke IP internal yang aneh, ini adalah temuan (*Finding*) tingkat kritis pertama Anda.

3.4 Profil Musuh Kustom (YAML)

Platform Caldera berjalan di atas konfigurasi *YAML*. Tim CTI akan memberikan data taktik musuh, dan Tim Merah akan merangkainya menjadi blok *Adversary Profile*.

```
# Profil Adversary Caldera: Emulasi APT3 (Tiongkok) id: apt3_emulation_profile_v1 name: APT3 (Gothic Panda) Custom description: Rangkaian simulasi spionase internal APT3 atomic_ordering: - ID Teknik: T1033 (System Owner/User Discovery) - 43b3754c-def4-4699-a673-1d85648fda6a - ID Teknik: T1003 (Credential Dumping - Mimikatz) - 61a1532f-45a2-4a0b-8d2a-e8db5023ed53
```

Saat operasi dimulai, agen *Sandcat* akan mengeksekusi langkah pertama. Jika ia sukses mengumpulkan pengguna OS, ia melapor kembali, lalu peladen Caldera akan otomatis menginstruksikan langkah kedua (mengunduh Mimikatz) secara asinkron tanpa bantuan operator manusia.

3.5 Menjalankan Operasi & Fact Sources

Fitur tercanggih Caldera adalah **Fact Sources (Sumber Fakta)**. Caldera tidak sekadar mengeksekusi skrip statis; ia memahami konteks dinamis. Jika langkah 1 (Eksplorasi) berhasil menemukan nama *Share Folder* rahasia, Caldera menyimpan nama *folder* itu sebagai "Fakta" (*Fact*).

Pada langkah 2 (Eksfiltrasi), Caldera secara otomatis menggunakan "Fakta" yang baru ditemukan tersebut ke dalam perintah pencurian datanya. Mesin operasi ini merencanakan tindakannya sendiri (*Planner*) berdasarkan kondisi lapangan.

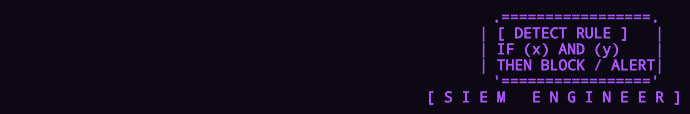
Tim Biru harus sangat sigap. Operasi Caldera bisa menyebar dari 1 PC uji coba ke PC lain jika jaringan tidak disegmentasi (*Lateral Movement*). Oleh karena itu, aturan keterlibatan (*Rules of Engagement*) membatasi agen Sandcat hanya boleh beroperasi pada *VLAN* khusus isolasi yang tetap dipantau penuh oleh sensor EDR perusahaan.

3.6 Caldera vs EDR: Mengaudit Respons EDR

Saat Caldera menembakkan profil *Ransomware* atau *Wiper*, tujuan kita bukan hanya melihat log di SIEM, tetapi menguji mesin mitigasi otomatis dari **EDR (Endpoint Detection and Response)** seperti *CrowdStrike Falcon* atau *SentinelOne*.

Jika Anda telah mengkonfigurasi EDR ke mode *Block / Protect*, Anda ingin melihat Sandcat "dibunuh" (*Killed/Quarantined*) di tengah jalan. Jika Caldera berhasil menjalankan 10 dari 15 langkah serangan sebelum EDR akhirnya bereaksi dan membunuh prosesnya, Tim Biru harus mengaudit: *Mengapa EDR butuh 10 langkah untuk menyadari bahwa ini berbahaya?*

Data ini menjadi peluru kuat bagi tim arsitektur keamanan untuk bernegosiasi dengan vendor EDR, meminta perbaikan deteksi (*Engine Updates*), atau memaksa Tim Biru menulis aturan deteksi kustom tambahan di atas kebijakan (*Policy*) bawaan EDR.



BAGIAN IV

Validasi & Rekayasa Deteksi
(Detection Engineering Lifecycle)

BAB 4: VALIDASI DETEKSI

4.1 Lifecycle Rekayasa Deteksi Terstruktur

Latihan simulasi Caldera/Atomic selesai. Layar EDR (SentinelOne) Anda berkedip merah terang (Alarm), dan SIEM Anda dipenuhi log. Apa langkah selanjutnya?

Tugas **Detection Engineer** dimulai di sini. Ini bukan sekadar tentang: *"Oh, alarm menyala, berarti kita aman."* Rekayasa deteksi (*Detection Engineering*) memastikan logika peringatan (KQL/SPL Query) akurat secara matematis dan tidak menimbulkan *Alert Fatigue*.

Lifecycle Penulisan Aturan:

1. **Research:** Memahami teknik dari hasil eksekusi *Atomic Red Team*.
2. **Query Draft:** Menulis sintaks `process.name == "cmd.exe" AND process.command_line : "*whoami*"`.
3. **Baseline / Noise Test:** Menjalankan kueri draf tersebut pada log 30 hari terakhir. Jika menyala 5.000 kali secara sah, aturan gagal.
4. **Tuning:** Menambahkan logika eksklusi (*Whitelisting*).

4.2 Matriks Klasifikasi: True Positive vs False Negative

Tujuan utama dari pengujian keamanan adalah menghindari kegagalan klasifikasi. Dalam matematika rekayasa deteksi, kita mengenal empat kuadran:

- **True Positive (Keberhasilan Mutlak):** Serangan Caldera terjadi, dan SIEM Anda memberikan alarm peringatan. Ini adalah tujuan akhir kita.
- **True Negative (Aman):** Tidak ada serangan, dan SIEM diam. Ini normal.
- **False Positive (Kebisingan/Noise):** Tidak ada serangan sungguhan (hanya *Admin* TI yang bekerja normal), tetapi SIEM memberikan alarm kritis. Ini membakar mental analis dan harus dikalibrasi (*Tuned*).
- **False Negative (Bencana/Disaster):** Serangan *Atomic Red Team* dieksekusi dengan sukses, target terkompromi, tetapi **SIEM Anda diam saja (Tidak ada Alarm)**. Inilah yang paling ditakuti, dan alasan mengapa *Purple Teaming* diciptakan—untuk mengungkap Celah Buta (*Blind Spots*) ini sebelum peretas sungguhan yang menemukannya.

4.3 Mengkalibrasi Supresi (Tuning Logic)

Mari kita lihat skenario *Purple Team* riil (*KQL - Kibana Query Language*). Simulasi serangan menunjukkan peretas melakukan enumerasi *Domain Admins*. Kita ingin menangkap eksekusi `net group "Domain Admins" /domain`.

```
// Aturan Draf Awal (Buruk/Terlalu Luas) process.name : "net.exe" AND process.args : ("group" AND "domain admins") // Aturan Akhir (Tuned - Dikalibrasi via Suppression) process.name : "net.exe" AND process.args : ("group" AND "domain admins") AND NOT process.parent.name : "nessusd.exe" AND NOT host.ip : "10.0.0.55"
```

Aturan akhirnya kini secara presisi di-*Tuned*. Ia akan diam terhadap pemindai (*Scanner*) internal, tetapi memicu Alarm Kritis jika ada agen *Caldera* yang mengeksekusi dari PC Staf.

4.4 Evaluasi Celah Sumber Log (Data Quality)

Seringkali, Tim Biru menyadari bahwa kegagalan deteksi (*False Negative*) tidak disebabkan oleh kueri yang buruk, melainkan oleh ketiadaan data. Fenomena ini disebut **Log Source Gap**.

Jika simulasi Caldera menghapus log *Windows Security* menggunakan perintah `wevtutil cl Security` (Teknik MITRE T1070.001), dan Anda tidak mendapatkan peringatan apa pun, Anda mungkin akan menyalahkan SIEM. Padahal, masalahnya adalah agen penerus log (seperti *Winlogbeat* atau *Splunk Universal Forwarder*) Anda dikonfigurasi secara salah dan memang tidak mengirimkan *Event ID 1102 (The audit log was cleared)* sejak awal.

Hasil dari *Purple Teaming* bukan hanya pembaruan aturan KQL, tetapi juga **Tugas Infrastruktur (Infrastructure Tickets)**: Mengonfigurasi ulang GPO *Active Directory*, memperbarui berkas *Auditd* di peladen Linux, atau mengaktifkan pemantauan *Command Line* di *Sysmon*. Deteksi hanya sebaik data yang diterimanya.



BAGIAN V

Operasionalisasi & Metrik
(SecOps CI/CD Pipeline)

BAB 5: OPERASIONALISASI METRIK

5.1 Perencanaan Eksekusi (Rules of Engagement)

Latihan *Purple Team* tidak boleh dilakukan secara mendadak atau tanpa persiapan. Layaknya operasi militer, ia membutuhkan **Rules of Engagement (RoE)** atau Aturan Keterlibatan yang disetujui oleh level eksekutif.

RoE mendefinisikan batasan absolut: *Sistem mana yang boleh diserang? (Hanya PC Staging, bukan Server Database Produksi). Jam berapa simulasi dilakukan? (Di luar jam sibuk atau saat jam kerja untuk menguji kesigapan analis?).*

Selain itu, RoE harus menjamin keselamatan jaringan. Agen *Caldera* atau skrip *Atomic* harus dikonfigurasi agar tidak pernah mengirimkan data rahasia perusahaan ke luar (*No real exfiltration*), melainkan hanya mengeksfiltrasi berkas teks tiruan (*Dummy Data*). Ini memastikan bahwa latihan untuk mencegah kebocoran data tidak secara ironis menyebabkan kebocoran data itu sendiri.

5.2 Komunikasi Operasional & Fase Hotwash

Di hari pelaksanaan, Tim Merah dan Tim Biru duduk di saluran komunikasi yang sama (Ruang Rapat atau *Channel Zoom/Teams* yang didedikasikan). Pendekatan *"Over-the-shoulder"* ini krusial.

Setiap kali Tim Merah menekan tombol eksekusi, mereka berseru: *"T1059 dieksekusi pada 10:45 WIB di host WIN-DESK-01"*. Tim Biru mengonfirmasi: *"Log diterima pada 10:46 WIB, namun alert tidak terpicu."* Koreksi langsung dilakukan saat itu juga.

Setelah seluruh skenario selesai, operasi ditutup dengan rapat **Hotwash (Debriefing)**. Dalam sesi ini, ego dikesampingkan. Fokus *Hotwash* adalah mendata ulang matriks keberhasilan (Berapa teknik yang terdeteksi, berapa yang lolos), dan menetapkan penanggung jawab (PIC) untuk memperbaiki celah log atau menulis ulang aturan SIEM sebelum latihan bulan depan dilakukan.

5.3 KPI & Metrik: Time-to-Detect (TTD)

Manajemen tingkat C-Level tidak memahami *Sysmon Event ID*. Mereka memahami waktu dan risiko. Latihan *Purple Team* harus menghasilkan metrik performa (*Key Performance Indicators*) yang jelas.

Dua metrik paling vital adalah:

- **Mean Time to Detect (MTTD):** Berapa menit selisih antara Tim Merah menekan tombol eksekusi, dengan munculnya alarm merah di dasbor SIEM Tim Biru? (Semakin kecil semakin baik, idealnya < 5 menit).
- **Mean Time to Respond (MTTR):** Berapa lama waktu yang dibutuhkan analis manusia untuk melihat alarm tersebut, membuka tiket insiden, dan menekan tombol isolasi jaringan pada mesin target?

Jika simulasi Caldera membuktikan bahwa MTTD SOC Anda adalah 45 menit, Anda memiliki argumen kuat berbasis data untuk meminta anggaran perangkat lunak otomatisasi (SOAR) kepada direksi.

5.4 Automasi Continuous Validation (CI/CD)

Mengeksekusi pengujian secara manual setiap bulan sangat melelahkan. Perusahaan keamanan yang matang mengadopsi konsep **Continuous Validation (Validasi Berkelanjutan)**, yang terinspirasi dari pipa *CI/CD (Continuous Integration)* pada rekayasa perangkat lunak (DevOps).

Mereka menggunakan alat otomasi *pipeline* (seperti GitLab CI atau Jenkins) yang dijadwalkan berjalan setiap malam (*Nightly Builds*). Pipa ini akan:

1. Secara otomatis memutar mesin virtual (VM) uji coba yang steril.
2. Menyuntikkan modul *Atomic Red Team*.
3. Menjalankan skrip Python untuk memeriksa API SIEM (Splunk/Elastic): *"Apakah peringatan X muncul dalam 5 menit terakhir?"*
4. Jika SIEM tidak menemukan peringatan tersebut, pipa *CI/CD* gagal (*Build Failed*) dan mengirimkan notifikasi *Slack* ke Tim SOC.

Ini menjamin bahwa pembaruan OS atau EDR tidak merusak deteksi Anda secara diam-diam (*Detection Drift*).

5.5 Integrasi SOAR dengan Emulasi

Pengujian *Purple Team* tidak berhenti pada deteksi. Untuk SOC yang matang, latihan ini juga menguji otot respons otomatis (**SOAR - Security Orchestration, Automation, and Response**).

Ketika *Caldera* mengeksekusi taktik ekstraksi data (*Exfiltration*), SIEM harus meneruskan alarm ke platform SOAR (seperti Cortex XSOAR atau Tines). SOAR kemudian secara otonom membaca IP peladen C2 Caldera, memanggil API *Palo Alto Firewall*, dan memblokir IP tersebut dalam hitungan detik.

Latihan *Purple Team* memvalidasi *Playbook SOAR* ini. Jika API *Firewall* gagal diakses karena perubahan kredensial minggu lalu (yang tidak disadari siapa pun), *playbook* akan gagal memblokir agen Caldera. Penemuan kegagalan integrasi SOAR di lingkungan uji coba ini menyelamatkan perusahaan dari kehancuran di saat serangan nyata benar-benar terjadi.

5.6 Manajemen Threshold & Keletihan Analis

Latihan berulang menyoroti masalah *Alert Fatigue*. Jika Tim Merah menjalankan *Port Scan* menggunakan Nmap dan SIEM memicu 100 tiket peringatan individual (satu tiket per *Port* yang dipindai), Analis SOC akan tenggelam dalam kebisingan.

Tim Biru merespons ini dengan menyesuaikan logika **Threshold (Ambang Batas)**. Alih-alih membuat satu alarm per kejadian, mereka mengubah aturan KQL menjadi agregasi: *"Memicu alarm HANYA JIKA satu IP sumber menyentuh lebih dari 50 port berbeda dalam jendela waktu 1 menit."*

Ketika Tim Merah mengulangi pemindaian Nmap, SIEM kini hanya menghasilkan 1 tiket insiden berkorelasi tinggi. Latihan *Purple Team* melatih empati sistem; memastikan bahwa keluaran dari rekayasa deteksi adalah intelijen yang dapat ditindaklanjuti, bukan sekadar *spam* peringatan.

5.7 Manajemen Eksklusi Aturan (Whitelisting)

Salah satu hasil paling nyata dari sesi *Purple Team* adalah perapian daftar eksklusi (*Whitelists*). Seringkali, aturan deteksi yang dibuat di masa lalu ditambal dengan pengecualian yang buruk, seperti: `AND NOT user.name == "Admin"`.

Tim Merah yang cerdik akan mengeksploitasi ini dengan sengaja mengganti nama akun palsu mereka menjadi "Admin" saat simulasi *Atomic*. Jika mereka berhasil menembus tanpa alarm, Tim Biru akan menyadari bahwa eksklusi berbasis nama (*String-based Exclusion*) sangat rapuh.

Hasil dari tinjauan *Purple Team* akan memaksa arsitek keamanan untuk mengubah metode *Whitelisting* menjadi berbasis kriptografi atau *Path* yang lebih ketat, misalnya: `AND NOT (process.hash.sha256 == "A1B2..." AND process.signature.status == "Valid")`. Kualitas deteksi meningkat secara drastis.

5.8 Pengujian Regresi (Regression Testing)

Dunia TI selalu berubah (*Dynamic Environment*). Pembaruan sistem operasi *Windows 11* terbaru mungkin saja merusak cara *Sysmon* membaca memori, yang pada gilirannya mematahkan 10 aturan deteksi terbaik SOC Anda secara diam-diam.

Menjalankan *Atomic Red Team* secara rutin bertindak sebagai **Pengujian Regresi (Regression Testing)**. Anda memverifikasi bahwa pertahanan yang berhasil bekerja pada bulan Januari, masih tetap bekerja pada bulan Desember setelah ratusan *Patch Update* infrastruktur diterapkan.

Tanpa siklus validasi *Purple Team*, SOC akan hidup dalam ilusi keamanan (*False Sense of Security*), percaya bahwa aturan deteksi YARA dan KQL mereka yang berusia dua tahun masih aktif melindungi perimeter, padahal sebenarnya sistem pengiriman log di belakangnya sudah putus sejak lama.

5.9 Visibilitas Cloud (AWS / Azure)

Operasi *Purple Team* tidak terbatas pada jaringan lokal (*On-Premise*). Di era komputasi awan, musuh menargetkan s3 *Buckets*, menyalahgunakan *Identity and Access Management (IAM)*, dan mengeksekusi fungsi *Serverless (AWS Lambda)* secara ilegal.

Kerangka kerja emulasi seperti **Stratus Red Team** (atau ekstensi *Atomic Cloud*) digunakan untuk mengeksekusi simulasi detonasi awan. Tim Merah akan mensimulasikan taktik: *"Mengekspor cadangan database RDS ke akun AWS eksternal yang tidak dikenal."*

Tim Biru, di layar lain, memvalidasi apakah layanan *AWS CloudTrail* berhasil menangkap log *API Call* `ModifyDBInstance`, meneruskannya ke Splunk, dan memicu alarm *Data Exfiltration*. Mengamankan infrastruktur awan membutuhkan integrasi *API Logging* yang ketat, dan simulasi ini membuktikan konfigurasi tersebut.

5.10 Pengujian Lingkungan Kontainer (Kubernetes)

Ekspansi lebih lanjut dari operasi Tim Ungu menyasar klaster *Kubernetes (K8s)*. Peretas modern menyusup ke dalam kontainer (*Docker*) dan mencoba melarikan diri (*Container Escape*) untuk mengambil alih *Host Node* (Teknik MITRE T1611).

Tim Merah menggunakan skrip khusus untuk mencoba mengeksekusi penunggangan (*Mounting*) direktori akar (*Root Directory*) *Host* ke dalam *Pod* Kubernetes yang rentan. Tim Biru harus mengandalkan alat visibilitas berbasis *eBPF* (seperti *Cilium* atau *Falco*) untuk mendeteksi anomali di tingkat *Kernel* ini.

Latihan *Purple Team* pada Kubernetes sangat menantang karena kontainer bersifat ephemeris (hilang dalam hitungan detik setelah tugas selesai). Jika SIEM terlambat menarik log, artefak forensik musuh akan musnah selamanya bersamaan dengan matinya *Pod* tersebut.

5.11 Model Kematangan SOC (Maturity Model)

Secara berkala, pimpinan perusahaan menggunakan data dari latihan emulasi untuk memetakan SOC mereka ke dalam skala **Detection Maturity Model (DMM)**.

- **Level 1 (Blind):** Tidak ada data log, tidak ada deteksi. Simulasi *Atomic* berhasil 100% tanpa disadari.
- **Level 2 (Collection):** Log terkumpul di SIEM, tetapi tidak ada peringatan otomatis. Analis harus mencarinya secara manual.
- **Level 3 (Alerting):** Aturan korelasi berfungsi, memicu alarm saat simulasi Caldera berjalan.
- **Level 4 (Enrichment):** Alarm menyala, dan SOAR secara otomatis menambahkan data *Threat Intel* ke tiket insiden sebelum analis membacanya.
- **Level 5 (Automated Response):** EDR dan SOAR secara otomatis membunuh proses *malware* dan memblokir IP dalam hitungan detik setelah eksekusi. Tim Biru hanya menerima laporan pasca-mitigasi.

5.12 Umpan Balik Cyber Threat Intelligence

Siklus *Purple Team* yang sempurna akan berputar kembali ke tim **Cyber Threat Intelligence (CTI)**. Di awal (Bab 1.3), CTI memberikan profil musuh (seperti APT Lazarus) kepada Tim Merah untuk diemulasikan.

Setelah latihan selesai dan celah ditutup, Tim Biru memberikan umpan balik (*Feedback Loop*) kepada tim CTI: *"Kami sekarang sudah 100% tahan terhadap teknik kredensial dumping milik Lazarus. Beri kami Profil Musuh kelompok peretas baru yang menargetkan kerentanan Cloud untuk jadwal tes bulan depan."*

Siklus tak berujung ini menjamin bahwa arsitektur keamanan perusahaan berkembang sejalan dengan evolusi taktik musuh global, mencegah SOC mengalami stagnasi dan kepuasan diri (*Complacency*) yang berbahaya.

5.13 Budaya Blameless (Tanpa Saling Menyalahkan)

Kunci keberhasilan jangka panjang *Purple Teaming* bukan pada teknologinya, melainkan pada psikologi tim. Jika latihan digunakan oleh manajemen untuk menghukum Tim Biru karena gagal mendeteksi serangan, Tim Biru akan menjadi defensif, menyembunyikan data, dan kolaborasi akan mati.

Operasi ini harus menganut budaya **Blameless Post-Mortem** (Evaluasi Tanpa Menyalahkan). *"Kegagalan deteksi adalah kegagalan sistem, bukan kegagalan analis."* Jika peringatan tidak menyala, itu karena alat (SIEM/EDR) belum dikalibrasi, atau anggaran visibilitas kurang, bukan karena analis malas.

Ketika Tim Merah dan Tim Biru duduk bersama menikmati kopi setelah simulasi *Caldera* yang intens, dan merayakan perbaikan konfigurasi SIEM bersama-sama, Anda telah menciptakan *Purple Team* yang sesungguhnya.

5.14 Pelaporan Eksekutif (C-Level Reporting)

Anggaran untuk membeli EDR premium atau memperluas lisensi Splunk bergantung pada pelaporan. Laporan *Purple Team* sangat disukai oleh eksekutif (CISO / CEO) karena laporannya terkuantifikasi (berbasis angka empiris).

Alih-alih berkata: *"Kita mungkin rentan terhadap Ransomware"*, manajer SOC dapat mempresentasikan graf *Radar Chart*: *"Bulan lalu, deteksi kita terhadap taktik Eksfiltrasi Data hanya 30%. Setelah latihan Purple Team dan perbaikan aturan KQL, deteksi kita terbukti secara empiris naik menjadi 85%. Kita membutuhkan tambahan anggaran lisensi log Cloud untuk menutup 15% sisa blind-spot."*

Data emulasi yang valid secara matematis ini adalah senjata politik paling ampuh bagi arsitek keamanan untuk mendapatkan dukungan finansial dari dewan direksi perusahaan.

5.15 Kesimpulan Operasional

Keamanan siber bukanlah sebuah keadaan statis; ia adalah sebuah kata kerja (proses). Anda tidak dapat membeli "keamanan" dalam bentuk kotak *Firewall* dan berasumsi pekerjaan telah selesai. Selama peretas terus berinovasi, sistem pertahanan Anda akan mengalami degradasi efektivitas seiring berjalannya waktu.

Mengadopsi kerangka kerja **Adversary Emulation (Atomic Red Team & MITRE Caldera)** adalah pengakuan kedewasaan operasional. Anda menantang sistem Anda sendiri, mencari celah secara proaktif, dan memperbaikinya secara terstruktur (*Detection Engineering*) sebelum musuh nyata mengeksploitasinya.

Selamat datang di era *Purple Teaming*, tempat asumsi dibuang, dan keamanan sejati dibangun di atas fondasi validasi teknis yang konstan.

GLOSARIUM EMULASI (A-M)

TERMINOLOGI	DEFINISI & KONSEP OPERASIONAL
Adversary Emulation	Praktik meniru kampanye TTP (Taktik) musuh nyata secara berurutan dan terstruktur, alih-alih hanya mencari kelemahan *software* seperti Pen-Test.
Atomic Red Team	Perpustakaan skrip serangan sumber terbuka (*Red Canary*) berbentuk ujian mikro (tes unit) yang dipetakan ke ID *MITRE ATT&CK*, sering dipanggil via PowerShell.
Continuous Validation	Proses mengotomatisasi pengujian serangan secara berkala (misal: setiap malam) menggunakan pipa CI/CD untuk memastikan aturan SIEM tidak rusak seiring berjalannya waktu.
Detection Engineering	Disiplin rekayasa sistem yang berfokus pada perancangan, penulisan kueri SIEM, dan pengelolaan *Alert Lifecycle* untuk menjamin deteksi yang akurat.
MITRE Caldera	Platform kerangka kerja emulasi musuh (C2 Otonom) buatan MITRE yang mengeksekusi agen skrip kampanye serangan terautomasi (*Abilities & Profiles*).

GLOSARIUM EMULASI (N-Z)

TERMINOLOGI	DEFINISI & KONSEP OPERASIONAL
Purple Teaming	Kolaborasi kerja sama waktu-nyata antara operasi serangan (Tim Merah/Emulasi) dan pertahanan (Tim Biru/SIEM) untuk mengukur dan memperbaiki visibilitas log.
Rules of Engagement (RoE)	Dokumen aturan yang disepakati eksekutif yang mengatur batasan, jadwal, dan target aman saat melakukan latihan serangan siber di dalam jaringan produksi.
Sandcat (54ndc47)	Agen (*Payload / Beacon*) bawaan dari platform MITRE Caldera yang ditanam pada mesin target untuk mengeksekusi perintah serangan dari peladen C2.
Threshold & Suppression	Logika matematis dan eksklusi bersyarat di dalam sintaks kueri SIEM untuk meminimalisasi munculnya peringatan palsu (*False Positives*).
True/False Positive	*True Positive:* Serangan nyata & alarm menyala. *False Positive:* Bukan serangan & alarm menyala. *False Negative:* Serangan nyata, namun alarm diam (Celah).



> Sistem keamanan modern tidak runtuh karena
> mereka tidak memiliki alat (tools).
> Mereka runtuh karena mereka berasumsi
> bahwa alat tersebut berfungsi.

The Assumed Breach

© 2026 All rights reserved.
Validasi Arsitektur Defensif Enterprise